

Enterprise Active Directory Lab - PSLabPractice

Enterprise Active Directory Lab — PSLabPractice

A hands-on home lab demonstrating enterprise Active Directory administration — OU/group design, GPO deployment, NTFS permission modeling, hybrid identity sync to Microsoft Entra ID, and real troubleshooting incidents (Kerberos clock skew, OAuth certificate/clock-drift failures, firewall diagnosis, Restricted Groups misconfiguration) resolved end-to-end.

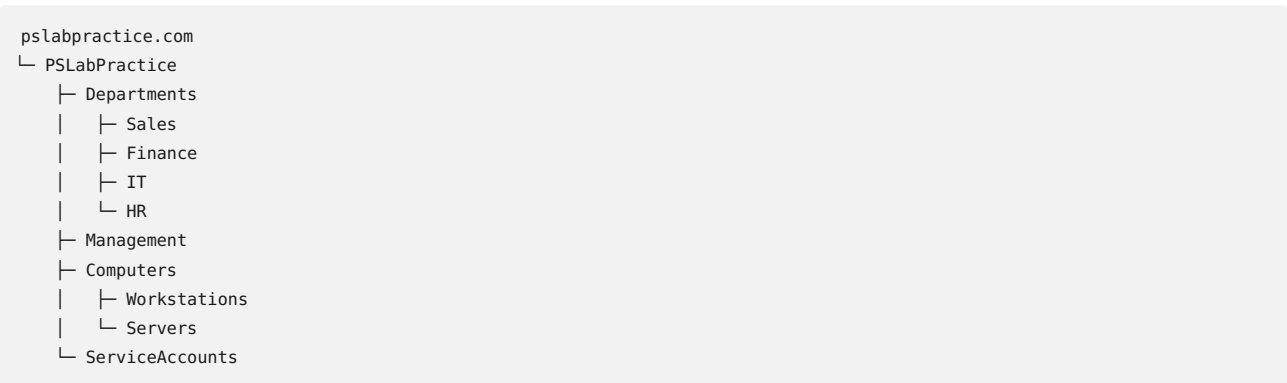
Status: On-prem AD/GPO/permissions build and hybrid identity sync (Entra Connect) complete and fully tested.

Overview

This lab simulates **PSLabPractice**, a fictional company with four departments (Sales, Finance, IT, HR) and a Management tier, built entirely on a self-hosted Domain Controller and a domain-joined client workstation. The goal was to move beyond textbook AD knowledge and build a working environment that mirrors the kinds of tickets, misconfigurations, and troubleshooting scenarios a real IT support role encounters day to day.

Environment: - **Domain Controller:** PS-DOMAIN (Windows Server), domain pslabpractice.com - **Client workstation:** DESKTOP-5K8UKTQ , domain-joined - Fully self-hosted, no external dependencies beyond internet access for updates and Entra ID sync

OU structure:



Users, groups, folder shares, and GPOs were all designed around this structure to reflect how a real organization segments identity, resources, and policy.

Skills & Concepts Demonstrated

Area	Details
AD Structure	OU design for GPO scope and delegated administration, distinct from access control
Group Strategy	AGDLP model (Account → Global Group → Domain Local Group → Permission) for scalable access management
File Permissions	NTFS permissions, inheritance and inheritance-breaking, effective access auditing
Network Shares	SMB share creation and the interaction between share-level and NTFS-level permissions

Group Policy	Drive mapping with item-level targeting, computer vs. user policy scope, Restricted Groups, GPO precedence (LSDOU, link order, Security Filtering)
User Lifecycle Management	Bulk provisioning via CSV import, disable/enable, password resets, account unlock, attribute updates, department transfers, delegation of administrative control
PowerShell Scripting	ActiveDirectory module cmdlets, splatting for reliable multi-parameter commands, CSV-driven bulk operations
Network Troubleshooting	Kerberos time-sync (clock skew) diagnosis and resolution, port-based connectivity testing, DNS/DHCP fundamentals
Firewall Administration	Windows Defender Firewall rule groups, inbound vs. outbound rules, firewall profiles (Domain/Private/Public), stateful vs. stateless filtering, diagnosing and resolving blocked remote management (RPC/WMI)
Security Principles	Least privilege, tiered administration, defense in depth, and a firsthand account of how misconfigured Restricted Groups can accidentally revoke administrative access
Hybrid Identity	Microsoft Entra Connect deployment, scoped OU-based sync design, Password Hash Synchronization, service account provisioning for automated/unattended processes

Project Phases

Phase 1 — OU Structure

Designed and built the organizational unit hierarchy to separate departments, computer objects, and service accounts — establishing the scaffolding that both Group Policy scope and delegated administration would later depend on.

Phase 2 — Users and Security Groups (AGDLP)

Created department-based user accounts and implemented the AGDLP group nesting model: Global groups represent departmental roles (`G_Sales` , `G_Finance` , etc.), nested into Domain Local groups (`DL_Sales_Modify` , etc.) that hold the actual resource permissions. This separation means department membership changes never require touching resource-level permissions directly.

Phase 3-5 — Folder Structure, NTFS Permissions, and Shares

Built a departmental folder structure and applied explicit NTFS permissions per Domain Local group, breaking default inheritance to enforce department-specific access. Shares were deliberately left open at the share-permission layer (`Everyone: Full Control`), pushing all real access control to the NTFS layer — a common enterprise pattern that avoids managing permissions in two places.

Phase 6 — Access Testing

Validated the full permission model with both **positive and negative** test cases — confirming department users could access only their own folder with Modify rights, Managers had read-only access across departments (excluding the intentionally restricted HR folder), and unauthorized access attempts were correctly denied.

Phase 7 — Group Policy Objects

Built and deployed three production-style GPOs: - **GPO-DriveMappings** — automatic per-department drive letter mapping using Group Policy Preferences with item-level targeting, evaluated against group membership at logon. - **GPO-SecurityBaseline** — machine inactivity lock timeout and password-protected screen saver,

split correctly across Computer Configuration (machine-scoped) and User Configuration (user-scoped) settings.

- **GPO-LocalAdmins** — Restricted Groups policy granting the IT security group local administrator rights on all workstations, avoiding the need for Domain Admin credentials during routine endpoint management.

Phase 8 — User Lifecycle Management

Simulated the operational tasks that make up the bulk of real-world AD administration: bulk user provisioning from CSV, account disable/enable for offboarding, password resets with forced change at next logon, account unlock, attribute updates, a full department transfer (OU move + group membership correction + verification that GPO-driven drive mappings updated automatically), and delegation of scoped administrative rights (password reset authority) to a specific OU without granting Domain Admin privileges.

Phase 9 — Hybrid Identity Sync (Microsoft Entra Connect)

Deployed Microsoft Entra Connect on the Domain Controller to synchronize on-premises Active Directory accounts to Microsoft Entra ID (Azure AD), establishing a working hybrid identity architecture on top of the existing on-prem environment.

Design decisions:

- Used **Custom installation** rather than Express, specifically to control sync scope rather than syncing the entire domain by default.
- Scoped **Domain/OU filtering** to only the `Departments` and `Management` OUs — explicitly excluding `Computers`, `ServiceAccounts`, and all default AD containers (`Users`, `Builtin`, `Domain Controllers`, etc.), so only real user identities that need cloud access are synced.
- Selected **Password Hash Synchronization** as the sign-in method — the simplest hybrid authentication model, syncing a hash (not the plaintext password) so users can authenticate to cloud services with their existing on-prem credentials.
- Let Entra Connect **auto-create a dedicated, scoped-down AD service account** for the ongoing sync process rather than running it under Domain Admin credentials — a concrete implementation of the least-privilege principle applied elsewhere in this project (see `GPO-LocalAdmins`), and a practical, hands-on illustration of the distinction between user accounts and service accounts in AD: the sync account is technically a standard AD user object, just provisioned and governed under different rules (no interactive logon, narrowly scoped permissions, intended to run unattended).
- Acknowledged and accepted that since `pslabpractice.com` is not a DNS-verified custom domain in the Entra tenant, synced users' cloud UPN falls back to the tenant's default `.onmicrosoft.com` suffix rather than their on-prem UPN — a known, expected limitation for a lab environment without a real, owned, publicly verifiable domain.

Result: All users from the `Departments` and `Management` OUs successfully synced and visible in the Microsoft Entra admin center, confirming a working end-to-end hybrid identity pipeline from on-prem AD to the cloud.

Notable Troubleshooting Incidents

Real infrastructure rarely works perfectly on the first attempt — these are documented here deliberately, since diagnosing and resolving them was as valuable as the initial build.

Kerberos clock skew blocking GPO application. Computer-scoped Group Policy silently failed to apply, with `gpupdate` reporting the client's clock was out of sync with the domain controller by several minutes — a Kerberos authentication requirement. Diagnosed via `w32tm /query /status`, resolved by correcting the DC's clock (the authoritative time source) and resyncing the client.

Restricted Groups misconfiguration locking out Domain Admins. After configuring a Restricted Groups GPO to grant the IT group local admin rights, the policy's membership list was found empty on a later review — which caused Restricted Groups' replace-not-merge behavior to strip even the *default* automatic Domain Admin local access from the target machine. Diagnosed by inspecting `net localgroup Administrators` output and the GPO's configured membership list, resolved by explicitly re-adding both the IT group and Domain Admins to the policy. This is a well-known real-world Restricted Groups pitfall, and the fix now serves as a standing best practice in this lab: always include Domain Admins explicitly whenever Restricted Groups is used.

Blocked remote management (RPC/WMI) preventing remote `gpresult` queries. A remote policy-reporting query failed with "RPC server is unavailable." Diagnosed using `Test-NetConnection` against port 135,

which confirmed the port was closed. Investigation with `Get-NetFirewallRule` showed the Windows Management Instrumentation (WMI) inbound rule group was disabled by default — expected behavior on a client OS, since remote management ports are not open out of the box the way they are on server editions. Resolved with `Enable-NetFirewallRule`, verified with a follow-up port test.

Certificate validity failure during Application-Based Authentication setup, traced to residual clock drift. Entra Connect's setup wizard failed at the "Configuring" step with a generic error: *"Microsoft Entra Connect could not configure application-based authentication for this server."* Reviewing the wizard's trace log directly (rather than relying on the generic UI error) surfaced the actual underlying exception: `AADSTS700027 - The certificate with identifier used to sign the client assertion is expired`. Closer inspection of the log's embedded timestamps showed the auto-generated certificate's validity window began *after* the timestamp of the authentication request that was rejecting it — a sub-hour timing mismatch, not a genuinely expired certificate. Root cause was traced back to the Domain Controller's time source: `w32tm /query /status` revealed the DC was relying on its own internal hardware clock (`Local CMOS Clock, Stratum 1`) rather than syncing against an external, authoritative time source — the same underlying class of issue as the earlier Kerberos clock-skew incident, this time surfacing in a cloud OAuth authentication context instead of on-prem Kerberos. Resolved by explicitly configuring the DC to sync against `pool.ntp.org` (`w32tm /config /manualpeerlist:... /syncfromflags:manual /reliable:yes /update`), confirming the change with `w32tm /query /status` (Source changed from `Local CMOS Clock` to `pool.ntp.org, Stratum 3`), and retrying the wizard — which then completed the authentication step successfully. This incident reinforced a broader lesson carried through the project: a domain's authoritative time source should always be explicitly configured against a reliable external reference rather than left on hardware defaults, since downstream authentication protocols — both Kerberos on-prem and OAuth/MSAL in the cloud — are highly sensitive to clock accuracy in ways that aren't always obvious from the initial error message.

Wizard instability during initial password hash sync. The Entra Connect configuration wizard appeared to hang indefinitely on the password hash synchronization step and ultimately crashed. Given that the install had auto-provisioned a SQL Server Express LocalDB instance running alongside AD DS, DNS, and the sync engine itself on a resource-constrained lab VM, this was most likely resource contention rather than a configuration fault. Despite the wizard's crash, the underlying `ADSync` service and sync engine completed the operation independently in the background — verified afterward via the Entra admin center, where all expected users appeared correctly synced. This is a useful reminder that a crashed management UI doesn't always mean a failed underlying operation, and that background service state should be checked independently before assuming a retry or reconfiguration is necessary.

Tools Used

- Windows Server (Domain Controller role, DNS, Group Policy Management)
 - Active Directory Users and Computers (ADUC) / `dsa.msc`
 - Group Policy Management Console (GPMC) / `gpmc.msc`
 - Windows PowerShell + ActiveDirectory module
 - Windows Defender Firewall with Advanced Security
 - `icacls`, `Test-NetConnection`, `gpresult`, `gpupdate`, `w32tm`
 - Microsoft Entra Connect Sync, Microsoft Entra admin center (entra.microsoft.com)
-

Why This Project

This lab was built to develop genuine, defensible hands-on experience with the concepts most commonly tested in IT support and systems administration interviews — not just to read about how AD, GPO, and NTFS permissions interact, but to build them, break them, and fix them under realistic conditions. Every scenario and troubleshooting incident documented here actually occurred during the build and was resolved through direct diagnosis, not scripted in advance.

Key Takeaways

- **Time synchronization is a silent dependency underneath nearly every authentication protocol.** Two separate incidents in this project — one Kerberos-based, one OAuth-based — traced back to the same root cause class (clock drift), surfaced through completely different, initially misleading error messages. This reinforced the habit of checking time sync early when any authentication-layer failure looks unrelated to permissions or connectivity.
- **A generic error message is a starting point, not an answer.** In both major incidents documented here, the wizard/tool's own error text ("could not configure application-based authentication," "RPC server is unavailable") described the symptom, not the cause. Going straight to logs (`gpresult` , Entra Connect trace logs) consistently got to the real root cause faster than iterating on the visible error alone.
- **In hindsight**, I'd configure the DC's external time source (`w32tm /config /manualpeerlist...`) as part of initial setup rather than as a reactive fix — both clock-related incidents in this project would likely have been avoided entirely with that configured from day one.
- **Restricted Groups' replace-not-merge behavior is a real, well-documented enterprise pitfall**, not a hypothetical one — experiencing it firsthand (including the momentary Domain Admin lockout) made the standard best practice ("always explicitly include Domain Admins") concrete rather than a rule memorized from documentation.